

Atbalsts platformas kiberdrošības stāvoklis

Stāvoklis 2026. gada 10. septembrī

Galvenais secinājums Platforma ir gatava skaidri marķētai demonstrācijai, un papildu tehnisku prezentācijas šķēršļu nav. PR #73 ir apvienots pēc sekmīgas CI pārbaudes, publiskajā vidē darbojas tieši apstiprinātais galvenā zara laidieni 664b5e5, sensitīvā diagnostika ir slēgta, bet atgriešanās un abu procesu automātiska atjaunošanās ir praktiski pārbaudīta. Tas vēl nav pilnas produkcijas gatavības vai juridiskas atbilstības apliecinājums.

Prezentācijas gatavība



Pilnas produkcijas drošības gatavība



Procenti ir kontroles gatavības novērtējums pēc koda, publiskās vides, procesa un pierādījumu stāvokļa. Tie nav sertifikācija, incidenta varbūtība vai juridisks atzinums.

Pārbaudīts pirms prezentācijas

Kontrole	Pierādītais rezultāts
Izlaidums	PR #73 apvienots pēc sekmīgas CI pārbaudes; publiskajā vidē izvērts galvenā zara SHA 664b5e58bde2fe39287b806c5606eb573a78c1ae.
Publiskā virsma	Galvenās lapas atbild ar 200; /api/health izdod tikai ok un būvējuma SHA ar no-store; publiskajā notikumu API nav iekšējo lauku.
Piekļuves kontrole	Anonīms /api/center/health un POST /api/live-data/refresh saņem 401.
Atkopšana	Izmēģināta pāreja uz iepriekšējo SHA 6636f6f un atjaunošana uz 664b5e5; abas versijas publiski identificējās pareizi.
Pieejamība	Lietotne un Cloudflare Tunnel darbojas ieslēgtos systemd lietotāja servisos ar Restart=always un pēc piespiedu procesa kļūmes atjaunojās automātiski.

Pašreizējā arhitektūra

Internets → Cloudflare starpniekserveris → Cloudflare Tunnel → lokāls izcelsmes servers → Vite priekšskatījuma serveris

Tunelis samazina tiešu servera ekspozīciju, bet neaizstāj WAF, hosta aizsardzību vai vairāku instanču pieejamību. Cloudflare Worker pastāv, taču nav publiskā domēna izcelsme.

Prezentācijā norādāmie ierobežojumi

- Apzināti pieļaujams** kopīgā Centra parole, sintētiski dati un Vite priekšskatījuma serveris tikai marķētā demonstrācijas režīmā.
- Nedrīkst apgalvot** pilnu produkcijas gatavību, aktīvus pielāgotus Cloudflare WAF noteikumus, darbību piesaisti individuāliem operatoriem vai ISO/IEC 27001 sertifikāciju.

Izolēto aspektu drošības stāvoklis

Aspekts	Gatavība	Pierādīts tagad	Atlikušais darbs
Publiskā virsma	92%	Minimāla /api/health atbilde, noteikts publisko lauku saraksts un sekmīgas anonīmās pārbaudes.	Perimetra pieprasījumu ierobežojumi un pārējo publisko datu projekciju periodiska pārbaude.
Izlaidumi un atkopšana	90%	Precīzs SHA, nemaināmi laidieni, restartēšana un atgriešanās pārbaudīta.	Aizstāt Vite priekšskatījuma serveri; ieviest otru izcelsmes instanci vai pārbaudītu Worker vidi.
MI un ārkārtas loģika	82%	Ārkārtas atbilde pirms MI; publicē tikai cilvēks; shēmas un avoti.	Promptu injekcijas un pretinieka scenāriju pārbaudes, centralizēta telemetrija un drošs pakalpojuma atslēgšanas režīms.
Repozitorijs un piegādes ķēde	74%	CI, 32 pārbaudes, būvējums, kritisku atkarību vārti, Dependabot un CODEOWNERS.	Galvenā zara aizsardzība, drošības brīdinājumi un augsto un vidējo atkarību sasniedzamības analīze.
Dati un Supabase	65%	Servera atslēgas, noturīga glabātuve, lauku minimizācija un validācija.	Datu karte, ietekmes uz datu aizsardzību novērtējums, glabāšana un dzēšana, minimālas datubāzes lomas, audits un atjaunošanas tests.

Izolēto aspektu drošības stāvoklis — turpinājums

Aspekts	Gatavība	Pierādīts tagad	Atlikušais darbs
Identitāte un sesijas	58%	Droši sīkfaiļi, izcelsmes pārbaudes, iekšējā diagnostika aiz sesijas.	Individuāli konti, MFA, sesiju atsaukšana, ierīču pārvaldība un darbību attiecināmība.
Faiļi	55%	Privāta glabāšana, īpašnieka, izmēra un deklarētā tipa pārbaudes.	Karantīna, ļaunprogrammatūras skenēšana un droša satura pārkodēšana.
Cloudflare perimetrs	45%	Cloudflare reversais starpniekserveris un tunelis; lietotnes pieprasījumu ierobežojumi; anonīma datu atsvaidzināšana ir slēgta.	R1 MI API un R3 pieteikšanās ātruma ierobežojumi, WAF un Security Events pārbaude.
Misijas un brīvprātīgie	45%	Cilvēka apstiprinājums publicēšanai, versiju kontrole, atkārtotu pieprasījumu drošums un pamata audits.	Kompetences un riska pārbaudes, četru acu princips, piekrišana un tās atsaukšana.
Monitorings un incidenti	55%	Minimāla veselības pārbaude, uzraudzīti procesi un pārbaudīta atgriešanās.	Pieejamības un ļaunprātīgas izmantošanas brīdinājumi, incidentu plāns, rezerves kopijas atjaunošana un galda mācības.

Svarīgākie atlikušā darba īpašnieki

- **Cloudflare zonas administrators** — ieteicamais termiņš **2026. gada 17. septembris** ieviest R1 MI API un R3 pieteikšanās ātruma ierobežojumus ar Managed Challenge, pēc tam septiņas dienas pārskatīt Security Events žurnālu. Ja prezentācija ir agrāk, ierobežojums jānorāda un lietotnes aizsardzība jāsaglabā kā kompensējoša kontrole.
- **GitHub repozitorija administrators** — ieteicamais termiņš **2026. gada 17. septembris** aizsargāt galveno zaru main ar obligātu PR, CI pārbaudi verify un CODEOWNERS apstiprinājumu; aizliegt piespiedu pārrakstīšanu un dzēšanu; ieslēgt pieejamos Dependabot un noslēpumu brīdinājumus.
- **Infrastrukturā īpašnieks** — ieteicamais termiņš **2026. gada 10. oktobris** aizstāt Vite priekšskatījuma serveri ar atbalstītu produkcijas izpildvidi vai pārbaudīt Worker migrāciju pirmsražošanas domēnā; pievienot pieejamības brīdinājumus.
- **Produkta privātuma un drošības īpašnieki** — **pirms personas datu pilota** pabeigt datu karti un novērtējumu par ietekmi uz datu aizsardzību (NIDA), ieviest individuālu identitāti un MFA, sesiju atsaukšanu, failu karantīnu, misiju riska pārbaudes un rezerves kopiju atjaunošanas mācības.

Galvenie uzbrukuma ceļi Programmatūrā tie ir API datu izguve, pieprasījumu plūdi un izmaksu izsmelšana, sesiju zādzība, promptu injekcija, ļaunprātīgi faili un piegādes ķēdes risks. Cilvēku un procesu pusē tie ir pikšķerēšana, kopīgi piekļuves dati, uzdošanās par partneri, iekšēja kļūda, nogurums un nepārbaudīta incidenta atjaunošana.

Standartu ceļš VDAR ir pirmais praktiskais pienākumu slānis personas datiem. Atsevišķi jānosaka Nacionālā kiberdrošības likuma, NIS2 un MK noteikumu Nr. 397 piemērojamība, Kiberneturības akta prasības katram tirgū laistam produktam un MI akta prasības pēc MI faktiskās lomas. Ieviešanai izmantot NIST CSF 2.0 un OWASP ASVS 5.0; ISO/IEC 27001 sākt tad, kad to prasa tirgus vai iepirkums.

Primārie avoti: [VDAR](#) · [Nacionālās kiberdrošības likums](#) · [MK Nr. 397](#) · [Kiberneturības akts](#) · [MI akts](#) · [NIST CSF 2.0](#) · [OWASP ASVS 5.0](#)

Produktu palaišanas lēmumi

- **Publiskā informācija un tikai lasāma karte** drošākais pirmais atsevišķais produkts; pirms publiskas produkcijas pievienot perimetra limitus un atbalstītu izpildvidi.
- **Iedzīvotāju ziņojumi** palaist tikai pēc datu kartes, glabāšanas un dzēšanas noteikumiem, centralizētiem pieprasījumu ierobežojumiem un failu karantīnas.
- **Vadības centrs** saglabāt demonstrācijas režīmā līdz individuāliem kontiem, MFA, sesiju atsaukšanai un pret viltojumiem aizsargātai audita uzskaiti.
- **Misijas un brīvprātīgo nosūtīšana** izolēt vai neizlaist līdz kompetences un riska pārbaudēm, piekrišanai un četru acu principam.
- **MI starpslānis** saglabāt tikai padomdevēja lomā ar minimizētu kontekstu un bez publicēšanas vai cilvēku nosūtīšanas tiesībām.